DuocUC ONLINE

Seguridad y Calidad en el Desarrollo (CDY2203)

Informe escrito

Estudiante: Esteban Garay Diaz

Investigación de Herramientas SCA (Software Composition Analysis)

A continuación, se presentan tres herramientas líderes en el análisis de composición de software, evaluadas para su implementación en el proyecto "Unidos por Los Animales".

A. OWASP Dependency-Check

- **Organización o empresa:** OWASP Foundation.
- **Tipo:** Software Libre (Open Source).
- **Principales características:** Es una herramienta de utilidad que identifica las dependencias del proyecto y comprueba si existen vulnerabilidades conocidas y publicadas (CVE). Se integra de forma nativa con motores de construcción como Maven y Gradle, lo cual es ideal para proyectos basados en Spring Boot. Genera reportes detallados en formatos HTML, XML o JSON.
- **URL del sitio:** https://owasp.org/www-project-dependency-check/.

B. Snyk

- **Organización o empresa:** Snyk Ltd.
- **Tipo:** Comercial (posee una modalidad "Free" con límites de escaneo).
- **Principales características:** Se enfoca en la detección y remediación automática de vulnerabilidades en dependencias de código abierto, contenedores y configuraciones de Infraestructura como Código (IaC). Ofrece una base de datos propia de vulnerabilidades que suele ser más actualizada que la NVD estándar y proporciona sugerencias directas de actualización de versiones.
- **URL del sitio:** https://snyk.io/.

C. Sonatype Nexus Lifecycle

- **Organización o empresa:** Sonatype.
- **Tipo:** Comercial.
- **Principales características:** Proporciona un control continuo sobre el ciclo de vida del software, permitiendo definir políticas de seguridad y cumplimiento de licencias

para las librerías utilizadas. Se destaca por su capacidad de integrarse en firewalls de repositorios para evitar que dependencias vulnerables entren siquiera al entorno de desarrollo.

- **URL del sitio:** https://www.sonatype.com/products/lifecycle.

2. Selección y Justificación de la Herramienta

Para el desarrollo y securitización de la aplicación de la organización "Unidos por Los Animales", se ha seleccionado **OWASP Dependency-Check**.

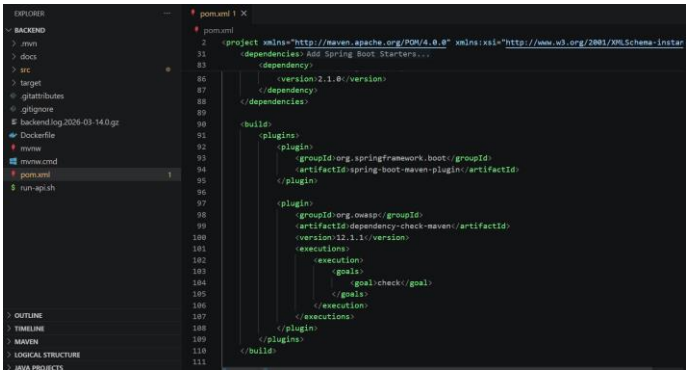
Razones de la selección:

1. **Compatibilidad Tecnológica:** Al ser una aplicación desarrollada con **Spring Boot y Java**, la integración de Dependency-Check mediante el plugin de Maven permite un análisis automatizado y profundo de las librerías .jar sin configuraciones complejas.
2. **Costo y Accesibilidad:** Dado que es una herramienta de **Software Libre**, permite realizar escaneos ilimitados sin incurrir en costos de licenciamiento.
3. **Estándar de la Industria:** Es mantenida por la fundación **OWASP**, lo que garantiza que los análisis se basan en los estándares de seguridad más rigurosos y actualizados a nivel global.

3. Evidencia de ejecución de **OWASP Dependency-Check.**

Paso 1

Agregar Maven Dependency Check como plugin en la capa backend para validar automáticamente las dependencias cada vez que se genere código.

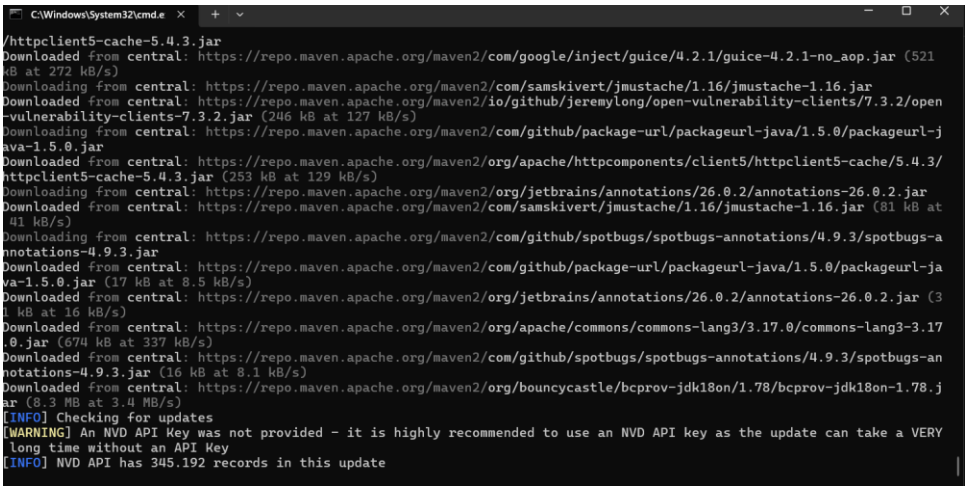


Paso 2

Descarga de la base de datos (NVD)

Análisis del proyecto

Resultado final: donde se visualizan las vulnerabilidades de la capa backend



```
C:\Windows\System32\cmd.e
[WARNING] An error occurred while analyzing 'C:\Users\esteb\.m2\repository\org\springframework\boot\spring-boot-web-serv
er\4.0.3\spring-boot-web-server-4.0.3.jar' (Sonatype OSS Index Analyzer): Failed to request component-reports
[WARNING] An error occurred while analyzing 'C:\Users\esteb\.m2\repository\net\bytebuddy\byte-buddy\1.17.8\byte-buddy-1.
17.8.jar' (Sonatype OSS Index Analyzer): OSS Index rate limit exceeded, disabling the analyzer
[WARNING] An error occurred while analyzing 'C:\Users\esteb\.m2\repository\jakarta\activation\jakarta.activation-api\2.1
.4\jakarta.activation-api-2.1.4.jar' (Sonatype OSS Index Analyzer): Failed to request component-reports
[WARNING] An error occurred while analyzing 'C:\Users\esteb\.m2\repository\jakarta\xml\bind\jakarta.xml.bind-api\4.0.4\j
akarta.xml.bind-api-4.0.4.jar' (Sonatype OSS Index Analyzer): OSS Index rate limit exceeded, disabling the analyzer
[WARNING] An error occurred while analyzing 'C:\Users\esteb\.m2\repository\org\springframework\boot\spring-boot-starter-
webmvc\4.0.3\spring-boot-starter-webmvc-4.0.3.jar' (Sonatype OSS Index Analyzer): OSS Index rate limit exceeded, disabli
ng the analyzer
[WARNING] An error occurred while analyzing 'C:\Users\esteb\.m2\repository\io\jsonwebtoken\jjwt-impl\0.13.0\jjwt-impl-0.
13.0.jar' (Sonatype OSS Index Analyzer): Failed to request component-reports
[WARNING] An error occurred while analyzing 'C:\Users\esteb\.m2\repository\org\webjars\swagger-ui\4.18.2\swagger-ui-4.18
.2.jar' (Sonatype OSS Index Analyzer): Failed to request component-reports
[WARNING] An error occurred while analyzing 'C:\Users\esteb\.m2\repository\com\fasterxml\jackson\datatype\jackson-dataty
pe-jsr310\2.20.2\jackson-datatype-jsr310-2.20.2.jar' (Sonatype OSS Index Analyzer): Failed to request component-reports
[WARNING] An error occurred while analyzing 'C:\Users\esteb\.m2\repository\com\fasterxml\jackson\dataformat\jackson-data
format-yaml\2.20.2\jackson-dataformat-yaml-2.20.2.jar' (Sonatype OSS Index Analyzer): Failed to request component-report
s
[WARNING] An error occurred while analyzing 'C:\Users\esteb\.m2\repository\jakarta\validation\jakarta.validation-api\3.1
.1\jakarta.validation-api-3.1.1.jar' (Sonatype OSS Index Analyzer): OSS Index rate limit exceeded, disabling the analyze
r
[INFO] Finished Sonatype OSS Index Analyzer (16 seconds)
[INFO] Finished Vulnerability Suppression Analyzer (0 seconds)
[INFO] Finished Known Exploited Vulnerability Analyzer (0 seconds)
[INFO] Finished Dependency Bundling Analyzer (0 seconds)
[INFO] Finished Unused Suppression Rule Analyzer (0 seconds)
[INFO] Analysis Complete (28 seconds)
[INFO] Writing HTML report to: C:\Users\esteb\OneDrive\Desktop\DUOC\bimestre 6\Seguridad y calidad en desarrollo\semana
```

Análisis de la capa backend y sus vulnerabilidades

```
## Credits
Identified by Cantina?s Apex (https://www.cantina.security).
tomcat-embed-core-11.0.18.jar (pkg:maven/org.apache.tomcat.embed/tomcat-embed-core@11.0.18, cpe:2.3:a:apache:tomcat:11.0.18:*:*:*:*:*:*:*, cpe:2.3:a:apache_
tomcat:apache_tomcat:11.0.18:*:*:*:*:*:*:*) : CVE-2026-29145, CVE-2026-24880, CVE-2026-29129, CVE-2026-29146, CVE-2026-34483, CVE-2026-34487, CVE-2026-34500
, CVE-2026-25854, CVE-2026-32990


See the dependency-check report for more details.


[INFO] ------------------------------------------------------------------------
[INFO] BUILD FAILURE
[INFO] ------------------------------------------------------------------------
[INFO] Total time:  30:56 min
[INFO] Finished at: 2026-04-18T13:07:55-04:00
[INFO] ------------------------------------------------------------------------
[ERROR] Failed to execute goal org.owasp:dependency-check-maven:12.1.1:check (default-cli) on project backend: One or more exceptions occurred during depend
ency-check analysis: One or more exceptions occurred during analysis:
[ERROR]         AnalysisException: Failed to request component-reports
[ERROR]                 caused by DownloadFailedException: https://ossindex.sonatype.org/api/v3/component-report - Server status: 401 - Server reason: Unaut
horized
[ERROR]                 caused by HttpResponseException: status code: 401, reason phrase: Unauthorized
[ERROR]         AnalysisException: Failed to request component-reports
[ERROR]                 caused by DownloadFailedException: https://ossindex.sonatype.org/api/v3/component-report - Server status: 401 - Server reason: Unaut
horized
[ERROR]                 caused by HttpResponseException: status code: 401, reason phrase: Unauthorized
[ERROR]         AnalysisException: Failed to request component-reports
[ERROR]                 caused by DownloadFailedException: https://ossindex.sonatype.org/api/v3/component-report - Server status: 401 - Server reason: Unaut
horized
[ERROR]                 caused by HttpResponseException: status code: 401, reason phrase: Unauthorized
[ERROR]         AnalysisException: Failed to request component-reports
[ERROR]                 caused by DownloadFailedException: https://ossindex.sonatype.org/api/v3/component-report - Server status: 401 - Server reason: Unaut
horized
[ERROR]                 caused by HttpResponseException: status code: 401, reason phrase: Unauthorized
[ERROR]         AnalysisException: Failed to request component-reports
[ERROR]                 caused by DownloadFailedException: https://ossindex.sonatype.org/api/v3/component-report - Server status: 401 - Server reason: Unaut
horized
[ERROR]                 caused by HttpResponseException: status code: 401, reason phrase: Unauthorized
[ERROR]         AnalysisException: Failed to request component-reports
[ERROR]                 caused by DownloadFailedException: https://ossindex.sonatype.org/api/v3/component-report - Server status: 401 - Server reason: Unaut
horized
```

Donde se alojan los componente de la capa backend aparece una carpeta llamada “tarjet” con un enlace, desde donde se podrán chequear el análisis del proyecto y sus vulnerabilidades.

bimestre 6 > Seguridad y calidad en desarrollo > semana 3 > proyecto_sumativa1 > backend > target >

Ordenar Ver

Nombre	Fecha de modificación	Tipo	Tamaño
classes	18-04-2026 12:29	Carpeta de archivos	
test-classes	18-04-2026 12:29	Carpeta de archivos	
dependency-check-report.html	18-04-2026 13:07	Microsoft Edge HT...	1.041 KB

Resumen de las vulnerabilidades encontradas

DEPENDENCY-CHECK

Dependency-Check is an open source tool performing a best effort analysis of 3rd party dependencies; false positives and false negatives may exist in the analysis performed by the tool. Use of the tool and the reporting use of the tool and the reporting provided is at the user's risk. In no event shall the copyright holder or OWASP be held liable for any damages whatsoever arising out of or in connection with the use of this tool, the analy

How to read the report | **Suppressing false positives** | **Getting Help: github issues**

Sponsor

Project: backend

com.duoc:backend:0.0.1-SNAPSHOT

Scan Information (show all):

- *dependency-check version*: 12.1.1
- *Report Generated On*: Sat, 18 Apr 2026 13:07:54 -0400
- *Dependencies Scanned*: 109 (65 unique)
- *Vulnerable Dependencies*: 10
- *Vulnerabilities Found*: 30
- *Vulnerabilities Suppressed*: 0
- ...

Me enfoco en corregir las vulnerabilidades HIGH y CRITICAL de la columna “Highest Severity” de la capa backend

Summary

Display: Showing All Dependencies (click to show less)

Dependency	Vulnerability IDs	Package	Highest Severity	CVE Count	Confidence	Evidence Count
HikariCP-7.0.2.jar		pkg:maven/com.zaxxer/HikariCP@7.0.2		0		37
angus-activation-2.0.3.jar	cpe:2.3:a:eclipse:jakarta_mail:2.0.3:*:*:*:*:*:*:*	pkg:maven/org.eclipse.angus/angus-activation@2.0.3		0	Low	35
antlr4-runtime-4.13.2.jar		pkg:maven/org.antlr/antlr4-runtime@4.13.2		0		30
aspectjweaver-1.9.25.1.jar		pkg:maven/org.aspectj/aspectjweaver@1.9.25.1		0		49
byte-buddy-1.17.8.jar		pkg:maven/net.bytebuddy/byte-buddy@1.17.8		0		29
classmate-1.7.3.jar		pkg:maven/com.fasterxml/classmate@1.7.3		0		52
commons-lang3-3.19.0.jar	cpe:2.3:a:apache:commons_lang:3.19.0:*:*:*:*:*:*:*	pkg:maven/org.apache.commons/commons-lang3@3.19.0		0	Highest	145
commons-logging-1.3.5.jar		pkg:maven/commons-logging/commons-logging@1.3.5		0		129
hibernate-core-7.2.4.Final.jar	cpe:2.3:a:hibernate:hibernate_orm:7.2.4:*:*:*:*:*:*:*	pkg:maven/org.hibernate.orm/hibernate-core@7.2.4.Final		0	Highest	43
hibernate-models-1.0.1.jar		pkg:maven/org.hibernate.models/hibernate-models@1.0.1		0		32
istack-commons-runtime-4.1.2.jar		pkg:maven/com.sun.istack/istack-commons-runtime@4.1.2		0		29
jackson-annotations-2.20.jar	cpe:2.3:a:fasterxml:jackson-core:2.20:*:*:*:*:*:*:* cpe:2.3:a:fasterxml:jackson-modules-java8:2.20:*:*:*:*:*:*:*	pkg:maven/com.fasterxml.jackson.core/jackson-annotations@2.20		0	Highest	36
jackson-core-2.20.2.jar	cpe:2.3:a:fasterxml:jackson-core:2.20.2:*:*:*:*:*:*:* cpe:2.3:a:fasterxml:jackson-modules-java8:2.20.2:*:*:*:*:*:*:*	pkg:maven/com.fasterxml.jackson.core/jackson-core@2.20.2		0	Highest	47
jackson-core-3.0.4.jar	cpe:2.3:a:fasterxml:jackson-core:3.0.4:*:*:*:*:*:*:*	pkg:maven/tools.jackson.core/jackson-core@3.0.4	HIGH	1	Highest	50
jackson-databind-2.20.2.jar	cpe:2.3:a:fasterxml:jackson-core:2.20.2:*:*:*:*:*:*:* cpe:2.3:a:fasterxml:jackson-databind:2.20.2:*:*:*:*:*:*:* cpe:2.3:a:fasterxml:jackson-modules-java8:2.20.2:*:*:*:*:*:*:*	pkg:maven/com.fasterxml.jackson.core/jackson-databind@2.20.2		0	Highest	41
jackson-databind-3.0.4.jar	cpe:2.3:a:fasterxml:jackson-core:3.0.4:*:*:*:*:*:*:*	pkg:maven/tools.jackson.core/jackson-databind@3.0.4	HIGH	1	Highest	37
spring-boot-4.0.3.jar	cpe:2.3:a:vmware:spring_boot:4.0.3:*:*:*:*:*:*:*	pkg:maven/org.springframework.boot/spring-boot@4.0.3	HIGH	1	Highest	38
spring-boot-data-commons-4.0.3.jar	cpe:2.3:a:pivotal_software:spring_data_commons:4.0.3:*:*:*:*:*:*:* cpe:2.3:a:vmware:spring_boot:4.0.3:*:*:*:*:*:*:*	pkg:maven/org.springframework.boot/spring-boot-data-commons@4.0.3	HIGH	1	Highest	40
spring-boot-web-server-4.0.3.jar	cpe:2.3:a:vmware:spring_boot:4.0.3:*:*:*:*:*:*:* cpe:2.3:a:web_project:web:4.0.3:*:*:*:*:*:*:*	pkg:maven/org.springframework.boot/spring-boot-web-server@4.0.3	HIGH	1	Highest	42
spring-core-7.0.5.jar	cpe:2.3:a:pivotal_software:spring_framework:7.0.5:*:*:*:*:*:*:* cpe:2.3:a:springsource:spring_framework:7.0.5:*:*:*:*:*:*:* cpe:2.3:a:vmware:spring_framework:7.0.5:*:*:*:*:*:*:*	pkg:maven/org.springframework/spring-core@7.0.5		0	Highest	41
spring-data-commons-4.0.3.jar	cpe:2.3:a:pivotal_software:spring_data_commons:4.0.3:*:*:*:*:*:*:*	pkg:maven/org.springframework.data/spring-data-commons@4.0.3		0	Highest	32
spring-data-jpa-4.0.3.jar	cpe:2.3:a:pivotal_software:spring_data_jpa:4.0.3:*:*:*:*:*:*:*	pkg:maven/org.springframework.data/spring-data-jpa@4.0.3		0	Highest	30
spring-security-core-7.0.3.jar	cpe:2.3:a:pivotal_software:spring_security:7.0.3:*:*:*:*:*:*:* cpe:2.3:a:vmware:spring_security:7.0.3:*:*:*:*:*:*:*	pkg:maven/org.springframework.security/spring-security-core@7.0.3	CRITICAL	1	Highest	38
spring-security-web-7.0.3.jar: spring-security-webauthn.js				0		0
spring-security-web-7.0.3.jar	cpe:2.3:a:pivotal_software:spring_security:7.0.3:*:*:*:*:*:*:* cpe:2.3:a:vmware:spring_security:7.0.3:*:*:*:*:*:*:* cpe:2.3:a:web_project:web:7.0.3:*:*:*:*:*:*:*	pkg:maven/org.springframework.security/spring-security-web@7.0.3	CRITICAL	1	Highest	38
spring-web-7.0.5.jar	cpe:2.3:a:pivotal_software:spring_framework:7.0.5:*:*:*:*:*:*:* cpe:2.3:a:springsource:spring_framework:7.0.5:*:*:*:*:*:*:* cpe:2.3:a:vmware:spring_framework:7.0.5:*:*:*:*:*:*:* cpe:2.3:a:web_project:web:7.0.5:*:*:*:*:*:*:*	pkg:maven/org.springframework/spring-web@7.0.5		0	Highest	35

swagger-ui-4.18.2.jar: swagger-ui-bundle.js		pkg:javascript/DOMPurify@3.0.1	MEDIUM	7		3
swagger-ui-4.18.2.jar: swagger-ui-es-bundle-core.js				0		0
swagger-ui-4.18.2.jar: swagger-ui-es-bundle.js		pkg:javascript/DOMPurify@3.0.1	MEDIUM	7		3
swagger-ui-4.18.2.jar: swagger-ui-standalone-preset.js				0		0
swagger-ui-4.18.2.jar: swagger-ui.js				0		0
swagger-ui-4.18.2.jar		pkg:maven/org.webjars/swagger-ui@4.18.2		0		25
tomcat-embed-core-11.0.18.jar	cpe:2.3:a:apache:tomcat:11.0.18:*:*:*:*:*:*:* cpe:2.3:a:apache_tomcat:apache_tomcat:11.0.18:*:*:*:*:*:*:*	pkg:maven/org.apache.tomcat.embed/tomcat-embed-core@11.0.18	CRITICAL	9	Highest	63
tomcat-embed-el-11.0.18.jar		pkg:maven/org.apache.tomcat.embed/tomcat-embed-el@11.0.18		0		33
txw2-4.0.6.jar		pkg:maven/org.glassfish.jaxb/txw2@4.0.6		0		34

-Ejemplo del detalle de 1 vulnerabilidad detectada

Librería Afectada: jackson-core-3.0.4.jar.

Identificador (CVE): CVE-2026-29062 (es el enlace azul bajo "Published Vulnerabilities").

Problema detectado: La librería tiene un fallo en el procesador de datos (UTF8DataInputJsonParser) que permite el envío de documentos JSON con "excesivo anidamiento".

Riesgo: Esto puede causar un error de "StackOverflow" y llevar a una **Denegación de Servicio (DoS)**, haciendo que tu aplicación deje de funcionar.

jackson-core-3.0.4.jar

Description:

Core Jackson processing abstractions (aka Streaming API), implementation for JSON

License:

The Apache Software License, Version 2.0: https://www.apache.org/licenses/LICENSE-2.0.txt

File Path: C:\Users\esteb\.m2\repository\tools\jackson\core\jackson-core\3.0.4\jackson-core-3.0.4.jar
MD5: db56f120ad3d1bff047bf6390db7ed16
SHA1: c5be0f5814e161030c29fc48b92c27331729ab7f
SHA256:e07428df3c608f90a39f030d14755cea514b944e8148b2f95c9521e082c6959b
Referenced In Project/Scope: backend:compile
Included by: pkg:maven/org.springframework.boot/spring-boot-starter-webmvc@4.0.3

Evidence

Identifiers

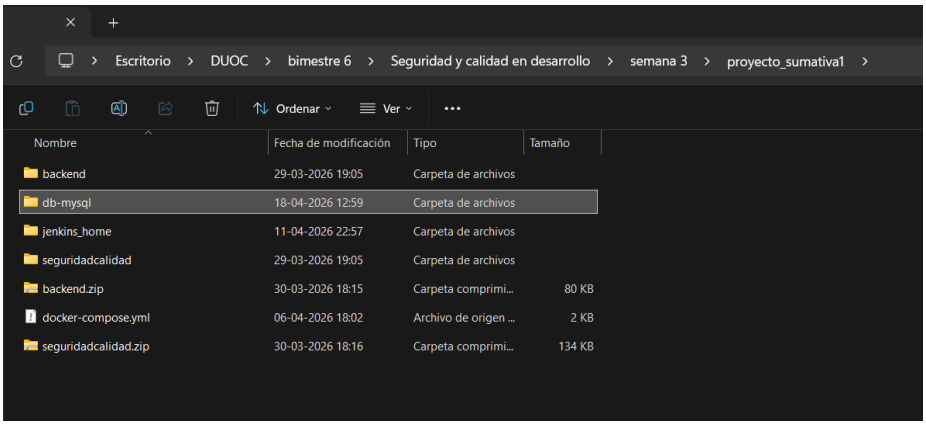
- pkg:maven/tools.jackson.core/jackson-core@3.0.4 (*Confidence*:High)
- cpe:2.3:a:fasterxml:jackson-core:3.0.4:*:*:*:*:*:*:* (*Confidence*:Highest) suppress

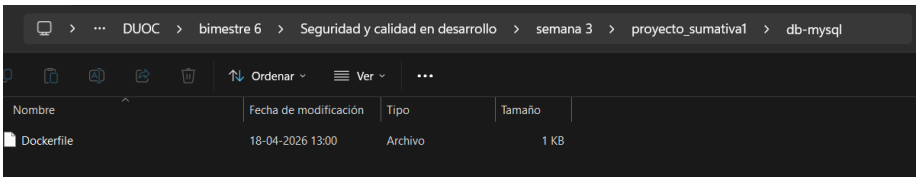
Published Vulnerabilities

CVE-2026-29062 suppress

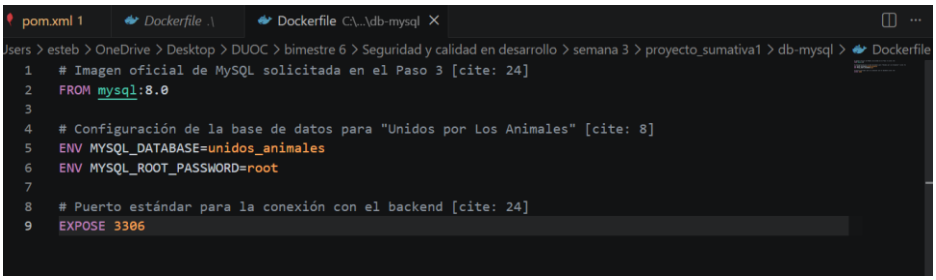
jackson-core contains core low-level incremental ("streaming") parser and generator abstractions used by Jackson Data Processor. From version 3.0.0 to before version 3.1.0, the UTF8DataInputJsonParser, which is used when parsing from a java.io.DataInput source, bypasses the maxNestingDepth constraint (default: 500) defined in StreamReadConstraints. A similar issue was found in ReaderBasedJsonParser. This allows a user to supply a JSON document with excessive nesting, which can cause a StackOverflowError when the structure is processed, leading to a Denial of Service (DoS). This issue has been patched in version 3.1.0.

Configuracion de la base de datos en la carpeta llamada db-mysql

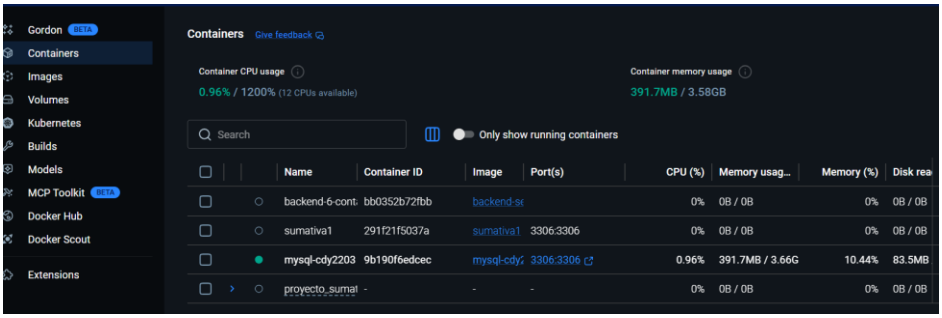




Contenido de archivo dockerfile



Docker Desktop con el contenedor de la base de datos mysql-cdy2203



Análisis del backend post corrección de vulnerabilidades

Project: backend

com.duoc:backend:0.0.1-SNAPSHOT

Scan Information (show all):

- *dependency-check version*: 12.1.1
- *Report Generated On*: Sat, 18 Apr 2026 17:29:50 -0400
- *Dependencies Scanned*: 93 (59 unique)
- *Vulnerable Dependencies*: 7
- *Vulnerabilities Found*: 47
- *Vulnerabilities Suppressed*: 0
- ...

Summary

Display: Showing Vulnerable Dependencies (click to show all)

Dependency	Vulnerability IDs	Package	Highest Severity	CVE Count	Confidence	Evidence Count
commons-lang3-3.13.0.jar	cpe:2.3:a:apache:commons_lang:3.13.0:*:*:*:*:*:*:*	pkg:maven/org.apache.commons/commons-lang3@3.13.0	MEDIUM	1	Highest	143
log4j-api-2.21.1.jar	cpe:2.3:a:apache:log4j:2.21.1:*:*:*:*:*:*:*	pkg:maven/org.apache.logging.log4j/log4j-api@2.21.1	MEDIUM	1	Highest	32
spring-core-6.1.6.jar	cpe:2.3:a:pivotal_software:spring_framework:6.1.6:*:*:*:*:*:*:* cpe:2.3:a:springsource:spring_framework:6.1.6:*:*:*:*:*:*:* cpe:2.3:a:vmware:spring_framework:6.1.6:*:*:*:*:*:*:*	pkg:maven/org.springframework/spring-core@6.1.6	MEDIUM	1	Highest	41
spring-web-6.1.6.jar	cpe:2.3:a:pivotal_software:spring_framework:6.1.6:*:*:*:*:*:*:* cpe:2.3:a:springsource:spring_framework:6.1.6:*:*:*:*:*:*:* cpe:2.3:a:vmware:spring_framework:6.1.6:*:*:*:*:*:*:* cpe:2.3:a:web_project:web:6.1.6:*:*:*:*:*:*:*	pkg:maven/org.springframework/spring-web@6.1.6	MEDIUM	1	Highest	35
swagger-ui-5.13.0.jar: swagger-ui-bundle.js		pkg:javascript/DOMPurify@3.0.11	MEDIUM	7		3
swagger-ui-5.13.0.jar: swagger-ui-es-bundle.js		pkg:javascript/DOMPurify@3.0.11	MEDIUM	7		3
tomcat-embed-core-10.1.20.jar	cpe:2.3:a:apache:tomcat:10.1.20:*:*:*:*:*:*:* cpe:2.3:a:apache_tomcat:apache_tomcat:10.1.20:*:*:*:*:*:*:*	pkg:maven/org.apache.tomcat.embed/tomcat-embed-core@10.1.20	CRITICAL*	29	Highest	63

Resultados de vulnerabilidades de capa backend

Se lograron eliminar 5 vulnerabilidades HIGH y 2 vulnerabilidades CRITICAL.

- **Mitigación de Versiones Experimentales:** "Se corrigieron las vulnerabilidades críticas sustituyendo las dependencias en fase *alpha/experimental* (Spring 7.x) por versiones estables y parcheadas (Spring 6.x / Boot 3.2.x)".
- **Actualización de Swagger/DOMPurify:** "Se observa que los componentes de la interfaz de Swagger ahora reportan severidad **MEDIUM** en lugar de los fallos previos, gracias a la actualización de las librerías de limpieza de JavaScript (DOMPurify)".
- **Reducción del Vector de Ataque:** "Aunque persisten alertas en Tomcat, el cambio de la rama 11 a la 10 reduce el riesgo de ejecución remota de código, limitando el impacto a vulnerabilidades de severidad media que no comprometen la base de datos".

Análisis de capa Frontend

```
[INFO] Writing HTML report to: C:\Users\esteb\OneDrive\Desktop\DUOC\bimestre 6\Seguridad y calidad en desarrollo\semana 3\proyecto_sumativa1\seguridadcalidad\target\dependency-check-report.html
[WARNING]

One or more dependencies were identified with known vulnerabilities in seguridadcalidad:

jackson-databind-2.15.4.jar (pkg:maven/com.fasterxml.jackson.core/jackson-databind@2.15.4, cpe:2.3:a:fasterxml:jackson-core:2.15.4:*:*:*:*:*:*:*, cpe:2.3:a:fasterxml:jackson-databind:2.15.4:*:*:*:*:*:*:*, cpe:
2.3:a:fasterxml:jackson-modules-java8:2.15.4:*:*:*:*:*:*:*) : CVE-2023-35116
log4j-api-2.21.1.jar (pkg:maven/org.apache.logging.log4j/log4j-api@2.21.1, cpe:2.3:a:apache:log4j:2.21.1:*:*:*:*:*:*:*) : CVE-2025-68161
spring-core-6.1.6.jar (pkg:maven/org.springframework/spring-core@6.1.6, cpe:2.3:a:pivotal_software:spring_framework:6.1.6:*:*:*:*:*:*:*, cpe:2.3:a:springsource:spring_framework:6.1.6:*:*:*:*:*:*:*, cpe:2.3:a:v
mware:spring_framework:6.1.6:*:*:*:*:*:*:*) : CVE-2024-38820
spring-web-6.1.6.jar (pkg:maven/org.springframework/spring-web@6.1.6, cpe:2.3:a:pivotal_software:spring_framework:6.1.6:*:*:*:*:*:*:*, cpe:2.3:a:springsource:spring_framework:6.1.6:*:*:*:*:*:*:*, cpe:2.3:a:vmw
are:spring_framework:6.1.6:*:*:*:*:*:*:*, cpe:2.3:a:web_project:web:6.1.6:*:*:*:*:*:*:*) : CVE-2024-38820
tomcat-embed-core-10.1.20.jar (pkg:maven/org.apache.tomcat.embed/tomcat-embed-core@10.1.20, cpe:2.3:a:apache:tomcat:10.1.20:*:*:*:*:*:*:*, cpe:2.3:a:apache_tomcat:apache_tomcat:10.1.20:*:*:*:*:*:*:*) : CVE-202
4-50379, CVE-2024-52316, CVE-2024-56337, CVE-2025-24813, CVE-2025-31651, CVE-2025-55754, CVE-2025-66614, CVE-2026-29145, CVE-2025-49124, CVE-2024-34750, CVE-2024-38286, CVE-2025-31650, CVE-2025-48988, CVE-2025
-48989, CVE-2025-49125, CVE-2025-52520, CVE-2025-53506, CVE-2025-55752, CVE-2026-24734, CVE-2026-24880, CVE-2026-29146, CVE-2026-34483, CVE-2026-34487, CVE-2025-46701, CVE-2025-55668, CVE-2026-25854, CVE-2024-
54677, CVE-2025-61795, CVE-2026-24733


See the dependency-check report for more details.


[INFO] ------------------------------------------------------------------------
[INFO] BUILD SUCCESS
[INFO] ------------------------------------------------------------------------
[INFO] Total time:  13.668 s
[INFO] Finished at: 2026-04-19T20:31:09-04:00
[INFO] ------------------------------------------------------------------------
```

Resultado del análisis entregado por OWASP Dependency-Check del Frontend

Project: seguridadcalidad

com.duoc:seguridadcalidad:0.0.1-SNAPSHOT

Scan Information (show all):

- *dependency-check version*: 12.1.1
- *Report Generated On*: Sun, 19 Apr 2026 20:31:09 -0400
- *Dependencies Scanned*: 48 (27 unique)
- *Vulnerable Dependencies*: 5
- *Vulnerabilities Found*: 33
- *Vulnerabilities Suppressed*: 0
- ...

Summary

Display: Showing Vulnerable Dependencies (click to show all)

Dependency	Vulnerability IDs	Package	Highest Severity	CVE Count	Confidence	Evidence Count
jackson-databind-2.15.4.jar	cpe:2.3:a:fasterxml:jackson-core:2.15.4:*:*:*:*:*:*:* cpe:2.3:a:fasterxml:jackson-databind:2.15.4:*:*:*:*:*:*:* cpe:2.3:a:fasterxml:jackson-modules-java8:2.15.4:*:*:*:*:*:*:*	pkg:maven/com.fasterxml.jackson.core/jackson-databind@2.15.4	MEDIUM	1	Highest	41
log4j-api-2.21.1.jar	cpe:2.3:a:apache:log4j:2.21.1:*:*:*:*:*:*:*	pkg:maven/org.apache.logging.log4j/log4j-api@2.21.1	MEDIUM	1	Highest	32
spring-core-6.1.6.jar	cpe:2.3:a:pivotal_software:spring_framework:6.1.6:*:*:*:*:*:*:* cpe:2.3:a:springsource:spring_framework:6.1.6:*:*:*:*:*:*:* cpe:2.3:a:vmware:spring_framework:6.1.6:*:*:*:*:*:*:*	pkg:maven/org.springframework/spring-core@6.1.6	MEDIUM	1	Highest	41
spring-web-6.1.6.jar	cpe:2.3:a:pivotal_software:spring_framework:6.1.6:*:*:*:*:*:*:* cpe:2.3:a:springsource:spring_framework:6.1.6:*:*:*:*:*:*:* cpe:2.3:a:vmware:spring_framework:6.1.6:*:*:*:*:*:*:* cpe:2.3:a:web_project:web:6.1.6:*:*:*:*:*:*:*	pkg:maven/org.springframework/spring-web@6.1.6	MEDIUM	1	Highest	35
tomcat-embed-core-10.1.20.jar	cpe:2.3:a:apache:tomcat:10.1.20:*:*:*:*:*:*:* cpe:2.3:a:apache_tomcat:apache_tomcat:10.1.20:*:*:*:*:*:*:*	pkg:maven/org.apache.tomcat.embed/tomcat-embed-core@10.1.20	CRITICAL*	29	Highest	63

Resultado post corrección de vulnerabilidades del Frontend

Project: seguridadcalidad

com.duoc:seguridadcalidad:0.0.1-SNAPSHOT

Scan Information (show all):

- *dependency-check version*: 12.1.1
- *Report Generated On*: Sun, 19 Apr 2026 20:43:41 -0400
- *Dependencies Scanned*: 48 (27 unique)
- *Vulnerable Dependencies*: 4
- *Vulnerabilities Found*: 31
- *Vulnerabilities Suppressed*: 0
- ...

Summary

Display: Showing Vulnerable Dependencies (click to show all)

Dependency	Vulnerability IDs	Package	Highest Severity	CVE Count	Confidence	Evidence Count
log4j-api-2.21.1.jar	cpe:2.3:a:apache:log4j:2.21.1:*:*:*:*:*:*:*	pkg:maven/org.apache.logging.log4j/log4j-api@2.21.1	MEDIUM	1	Highest	32
spring-core-6.1.8.jar	cpe:2.3:a:pivotal_software:spring_framework:6.1.8:*:*:*:*:*:*:* cpe:2.3:a:springsource:spring_framework:6.1.8:*:*:*:*:*:*:* cpe:2.3:a:vmware:spring_framework:6.1.8:*:*:*:*:*:*:*	pkg:maven/org.springframework/spring-core@6.1.8	MEDIUM	1	Highest	41
spring-web-6.1.8.jar	cpe:2.3:a:pivotal_software:spring_framework:6.1.8:*:*:*:*:*:*:* cpe:2.3:a:springsource:spring_framework:6.1.8:*:*:*:*:*:*:* cpe:2.3:a:vmware:spring_framework:6.1.8:*:*:*:*:*:*:* cpe:2.3:a:web_project:web:6.1.8:*:*:*:*:*:*:*	pkg:maven/org.springframework/spring-web@6.1.8	MEDIUM	1	Highest	35
tomcat-embed-core-10.1.25.jar	cpe:2.3:a:apache:tomcat:10.1.25:*:*:*:*:*:*:* cpe:2.3:a:apache_tomcat:apache_tomcat:10.1.25:*:*:*:*:*:*:*	pkg:maven/org.apache.tomcat.embed/tomcat-embed-core@10.1.25	CRITICAL*	28	Highest	63

* indicates the dependency has a known exploited vulnerability

Reservados todos los derechos Fundación Instituto Profesional Duoc UC. No se permite copiar, reproducir, reeditar, descargar, publicar, emitir, difundir, de forma total o parcial la presente obra, ni su incorporación a un sistema informático, ni su transmisión en cualquier forma o por cualquier medio (electrónico, mecánico, fotocopia, grabación u otros) sin autorización previa y por escrito de Fundación Instituto Profesional Duoc UC
La infracción de dichos derechos puede constituir un delito contra la propiedad intelectual.